

AWS Lab Setup #1

Cloud Infrastructure, Security & Compliance Build

Fictional Business: PayBridge Inc.

Digital Payments and Cash Flow Platform for Small Businesses

Student: Chike Okigbo

Course: CIT 360

Date: June 6, 2026

Contents

1. Business Overview and Requirements.....	3
1.1 Company Profile	3
1.2 Business Drivers.....	3
1.3 Functional Requirements.....	3
1.4 Non-Functional Requirements	Error! Bookmark not defined.
1.5 Mapping to Enterprise Architecture Domains	4
2. Compliance Documentation	5
2.1 Regulatory Scope	5
2.2 Shared Responsibility	5
2.3 Security First Tenet: Zero Trust Posture5	
2.4 Control Mapping	5
3. Target Architecture and Service Selection	7
3.1 As-Built Resource Inventory	Error! Bookmark not defined.
4. Lab Implementation Guide	9
4.1 Identity and Access Management (IAM)	9
4.2 Compute Server (EC2)	10
4.3 Network Boundary (VPC and Security Group)	11
4.4 Encryption Key (KMS)	12
4.5 Object Storage (S3).....	13
4.6 Audit Logging (CloudTrail)	14
4.7 Monitoring (CloudWatch)	15
5. Summary	16

1. Business Overview and Requirements

1.1 Company Profile

PayBridge Inc. is a fictional early stage financial technology (FinTech) startup based in Los Angeles, California. The company provides a web and mobile platform that lets small and mid-sized businesses accept card payments, reconcile transactions, and forecast cash flow from a single dashboard. Because PayBridge stores, processes, and transmits cardholder data on behalf of its merchant customers and produces financial reporting used for investor and audit purposes, it operates in one of the most heavily regulated areas of software.

Industry: Financial technology, focused on digital payments and merchant cash flow management.

Stage and scale: Seed stage startup, around 40 employees, expecting to onboard roughly 3,000 merchant accounts in year one with seasonal traffic spikes.

1.2 Business Drivers

- Protect sensitive cardholder and financial data to retain customer trust and avoid breach penalties.
- Demonstrate audit ready governance so the company can pass payment network and financial reporting assessments as it scales toward a future funding round.
- Keep infrastructure elastic and low cost while the merchant base grows unpredictably.
- Give a small engineering team strong, centrally governed controls rather than ad hoc manual administration.

1.3 Functional Requirements

ID	Requirement	Rationale
F1	Host the customer facing application on a managed compute server	Core product delivery to merchants
F2	Store transaction exports, statements, and merchant documents durably	Reporting, reconciliation, retention
F3	Authenticate and authorize internal staff with least privilege access	Separate duties across engineering, finance, support
F4	Encrypt all sensitive data at rest and in transit	Cardholder & financial data protection
F5	Record every administrative action for later audit	Forensics and accountability
F6	Monitor system health and alert on anomalies	Availability and incident response

1.4 Quality Requirements

ID	Category	Requirement
N1	Security	Zero trust posture; the business controls its own encryption keys rather than fully delegating to the provider.
N2	Compliance	Controls must be mapped to PCI-DSS and SOX, so the environment is assessment ready.
N3	Availability	Target 99.9% availability for the customer facing service.
N4	Auditability	A complete, tamper evident log of account activity must be retained.
N5	Cost	Stay within free tier where possible during buildout; tag resources for cost attribution.

1.5 Mapping to Enterprise Architecture Domains

Following the four-domain model from the course readings on establishing enterprise architecture on AWS, the requirements above distribute across the standard EA domains as follows. This keeps the technical build anchored to the business strategy rather than treating it as an isolated infrastructure exercise.

EA Domain	How PayBridge realizes it on AWS
Business	Actors (engineering, finance, support, admin) and their roles are defined and enforced through IAM, reflecting the actor-to-role relationships the business depends on.
Data	Cardholder and financial data are classified as sensitive and protected with KMS backed encryption and S3 controls.
Application	The payments/dashboard application runs on EC2 within a controlled network boundary.
Technology	Monitoring, logging, and configuration governance (CloudWatch, CloudTrail,) provide the auditability and change management foundation.

2. Compliance Documentation

Because PayBridge handles payment card data and produces financial reports, two regulatory regimes shape its control requirements: PCI-DSS and the Sarbanes-Oxley Act (SOX). This section defines each obligation and maps it to the specific AWS controls implemented in the lab.

2.1 Regulatory Scope

Regime	What it requires of PayBridge
PCI-DSS (Payment Card Industry Data Security Standard)	Protect stored cardholder data, encrypt transmission, restrict access on a need to know basis, assign unique IDs to each person with access, and track and monitor all access to network resources and cardholder data.
SOX (Sarbanes-Oxley Act)	Maintain internal controls over financial reporting, including segregation of duties, access controls on systems that produce financial data, and an audit trail demonstrating who changed what and when.

2.2 Shared Responsibility

Under the AWS shared responsibility model, AWS secures the underlying cloud infrastructure (the "security of the cloud"), while PayBridge is responsible for everything it configures on top (the "security in the cloud"). That includes IAM policies, encryption settings, network rules, logging, and monitoring. Every control in Section 4 sits on PayBridge's side of that boundary.

2.3 Security First Tenet, Zero Trust Posture

The course readings describe a Security First tenet on a spectrum from total trust to zero trust. PayBridge leans toward the zero trust side. Instead of letting AWS fully manage encryption, the business creates and controls its own customer managed key in AWS Key Management Service (KMS) and uses it to encrypt sensitive storage. That choice is what justifies having a dedicated KMS step in the build.

2.4 Control Mapping

The table below links each obligation to the AWS service and configuration that satisfies it.

Obligation	AWS Control Implemented	PCI-DSS / SOX Linkage
Unique IDs & least privilege	IAM users, groups, role based policies, MFA	PCI Req. 7 & 8; SOX segregation of duties
Encrypt data at rest	S3 default encryption using a customer managed KMS key	PCI Req. 3
Encrypt data in transit	TLS / HTTPS enforced; security-group rules	PCI Req. 4
Track all access & changes	CloudTrail logging all API activity to S3	PCI Req. 10; SOX audit trail

Obligation	AWS Control Implemented	PCI-DSS / SOX Linkage
Detect & alert on anomalies	CloudWatch metrics and alarms	PCI Req. 10.6; operational monitoring

3. Target Architecture and Service Selection

The services below were chosen to satisfy PayBridge's specific requirements rather than as a generic checklist. Each row ties a service back to the requirement IDs from Section 1.

AWS Service	Role in the architecture	Meets
IAM	Identity and access management, defines staff actors, role based groups, MFA, and EC2 service role	F3, N1
EC2	The application server hosting the PayBridge platform	F1, N3
VPC + Security Groups	Network boundary and firewall restricting inbound access	F4, N1
S3	Durable object storage for transaction exports and merchant documents	F2
KMS	Customer managed encryption key used to encrypt S3 data at rest	F4, N1
CloudTrail	Records every API call for a tamper evident audit trail	F5, N4
CloudWatch	Metrics, dashboards, and alarms for health and anomaly detection	F6, N3

Architecture in brief: Staff authenticate through IAM with MFA and least privilege group policies. The application runs on an EC2 instance inside a VPC, protected by a security group that only allows the ports it needs. Application data lands in an S3 bucket encrypted with PayBridge's own KMS key, with public access blocked and versioning on. CloudTrail captures all account activity into a dedicated log bucket and CloudWatch watches the instance and raises alarms.

3.1 Resource Inventory

The table below records the actual resources provisioned during the lab, in the US East (N. Virginia) us-east-1 region of AWS account 551656632092. It ties each screenshot in Section 4 to a concrete resource.

Service	Resource provisioned	Identifier
IAM	Admin user in Administrators group	PB-Admin
IAM	Service role for the application server	PayBridge-EC2-Role (trusts ec2)
EC2	Application server, Amazon Linux 2023, t3.micro	i-0cc64996f9c5a81f0 (PayBridge-App-Server)
Security Group	Firewall: SSH limited to my IP, HTTPS open	PayBridge-SG

Service	Resource provisioned	Identifier
KMS	Customer managed symmetric key, Enabled	alias paybridge-data-key (8f7c3cae...)
S3	Encrypted bucket, SSE-KMS, public access blocked, versioning on	paybridge-merchant-data-co-551656632092-us-east-1-an
CloudTrail	Multi region trail, log file validation enabled	paybridge-audit-trail
CloudWatch	Metric alarm on EC2 CPU > 70%, SNS email action	PayBridge-HighCPU

4. Lab Screenshots

4.1 Identity and Access Management (IAM)

Sets up the identities and access controls for the architecture: individual users, group based permissions, and multi factor authentication. Satisfies the unique ID and least privileged requirements.

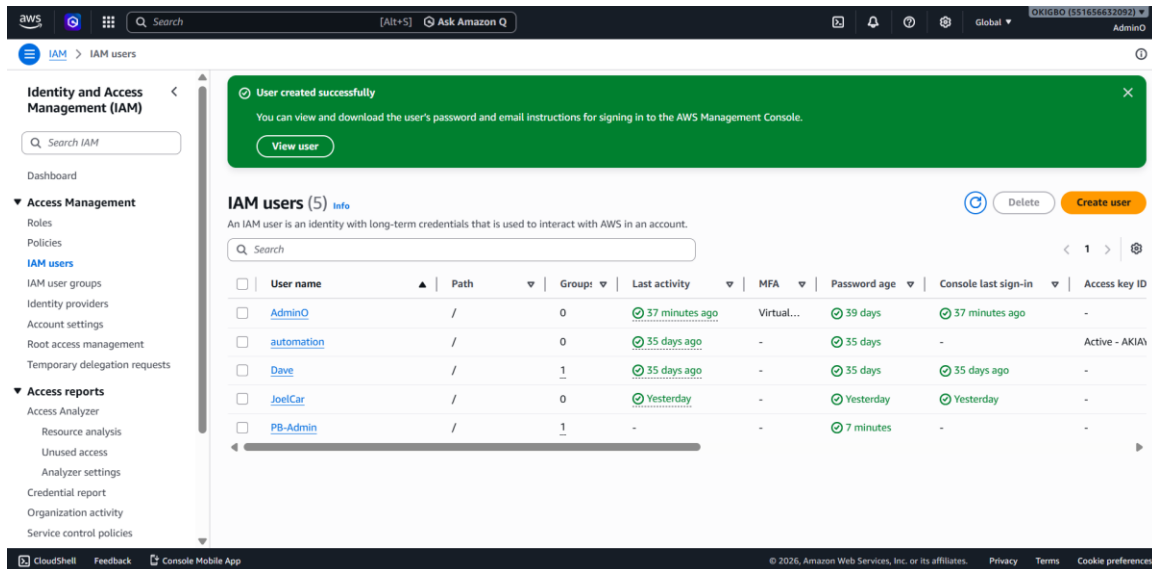


Figure 1.1 - IAM Users console showing pb-admin and the additional lab users created under the PayBridge account.

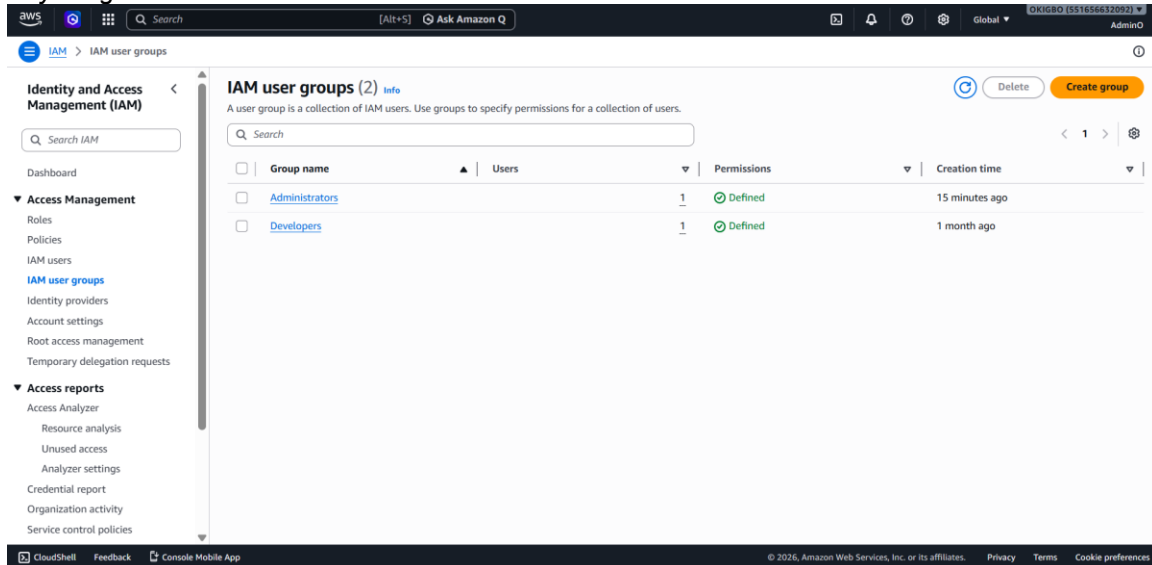


Figure 1.2 - IAM Groups page showing the Administrators and Developers groups used for role based access.

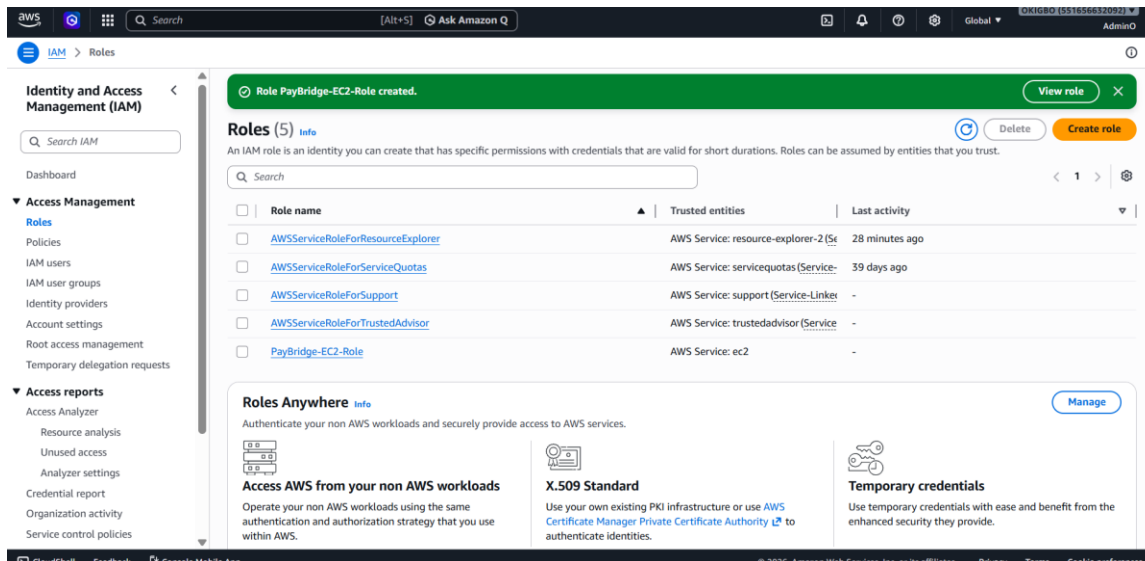


Figure 1.3 - IAM Roles page showing the PayBridge-EC2-Role created for the application server.

4.2 Compute Server (EC2)

Provisions the application server that hosts the PayBridge platform.

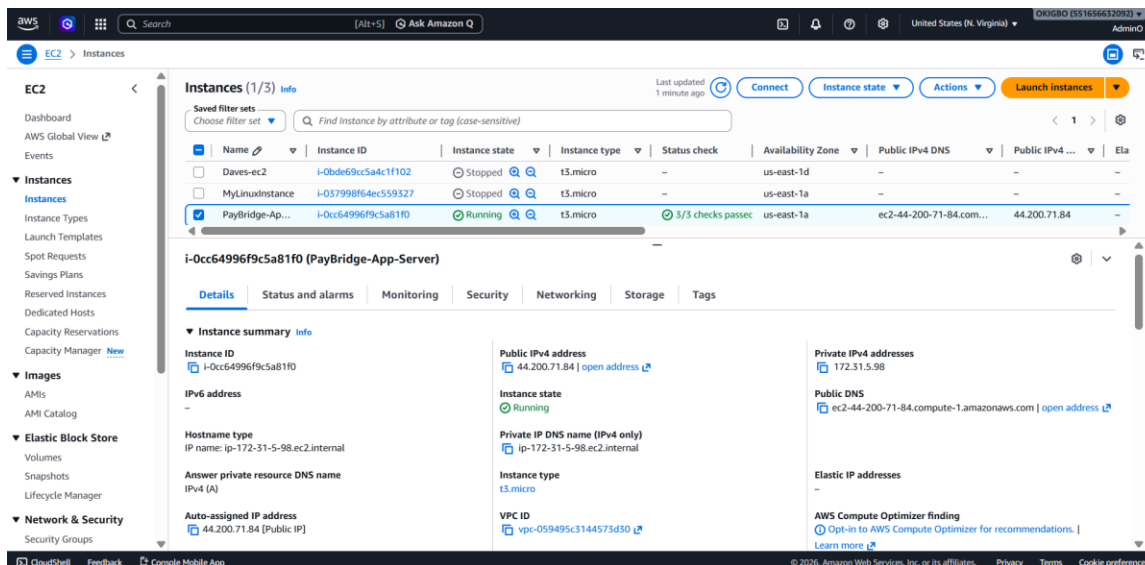


Figure 2.1 - EC2 Instances page showing PayBridge-App-Server in the Running state with its details panel.

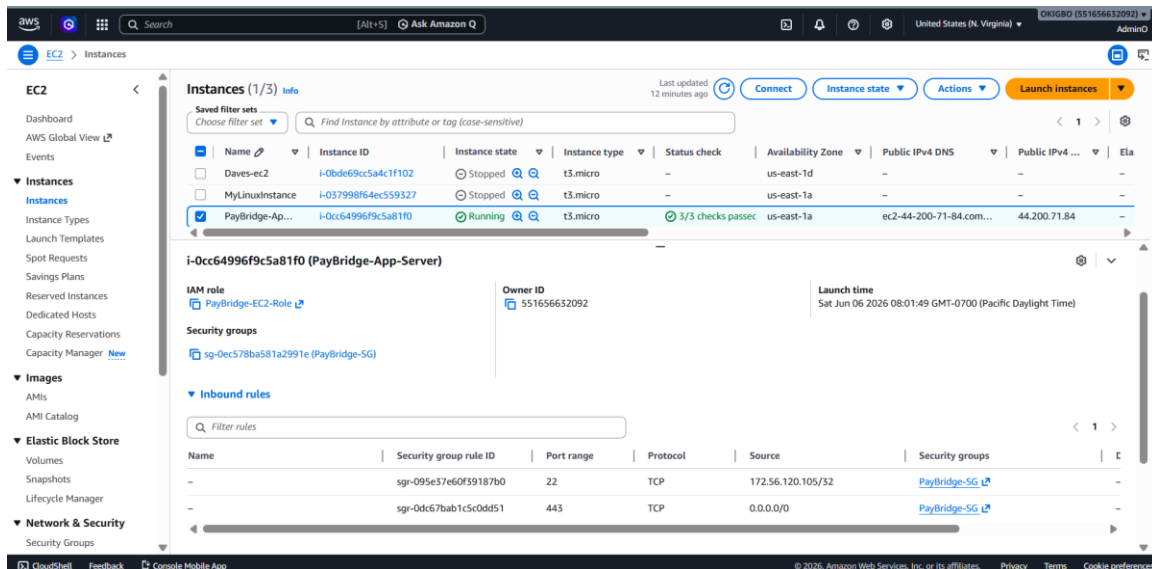


Figure 2.2 - EC2 instance details with the attached IAM role and the inbound security group rules visible.

4.3 Network Boundary (VPC and Security Group)

Demonstrates the network control layer that restricts who can reach the server, supporting the encryption in transit and zero trust requirements.

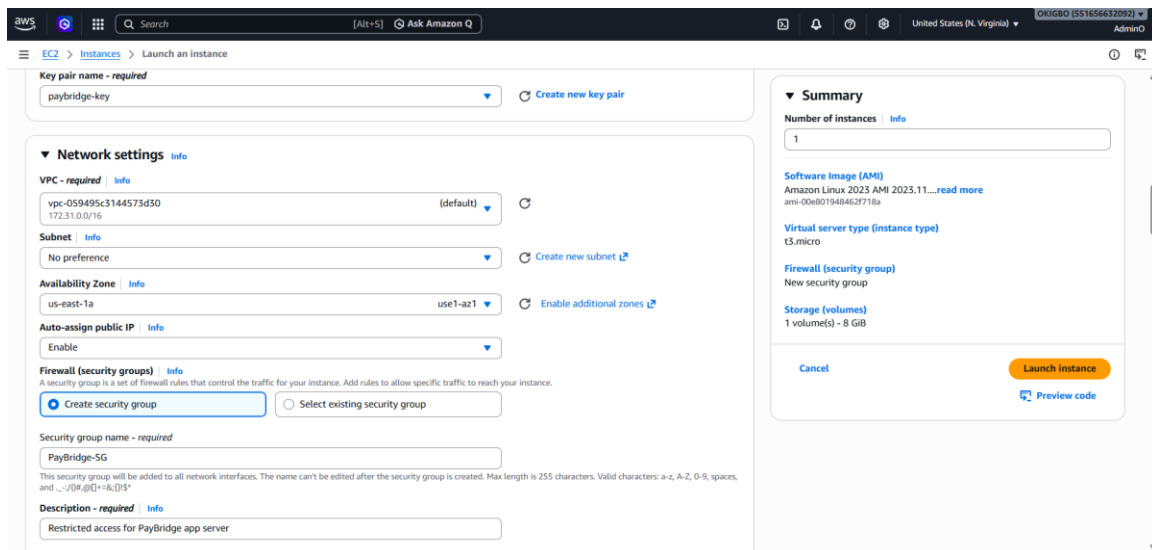


Figure 3.1 - EC2 launch network settings showing the VPC, subnet, and security group selected for PayBridge-App-Server.

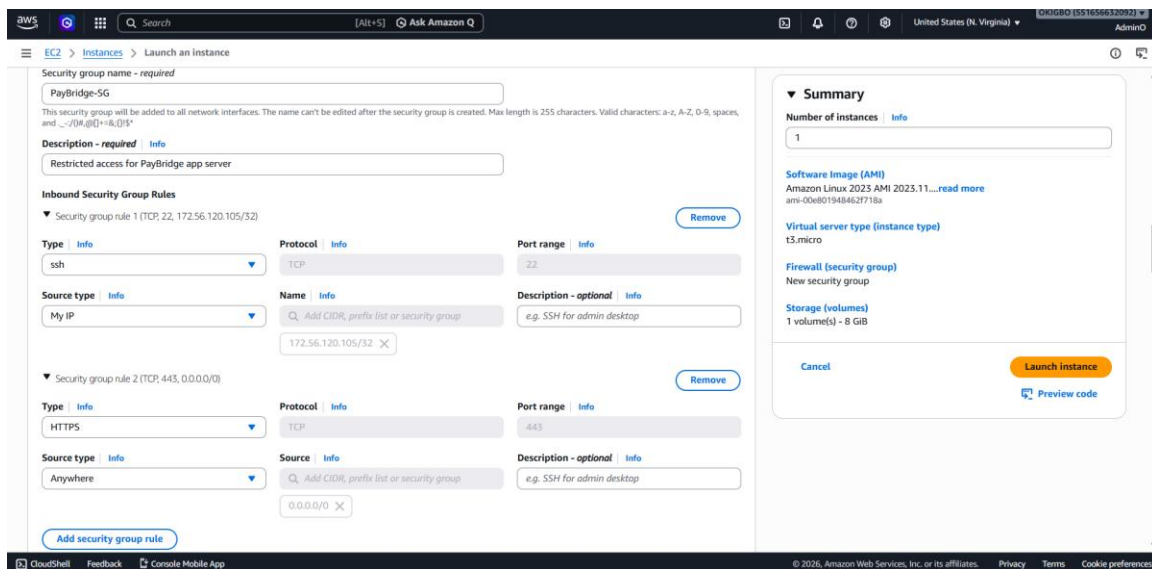


Figure 3.2 - Security group inbound rules limiting SSH access to a specific IP and exposing HTTPS for PayBridge web traffic.

4.4 Encryption Key (KMS)

Implements the zero trust, customer managed key decision from Section 2.3. PayBridge owns the key used to encrypt its data.

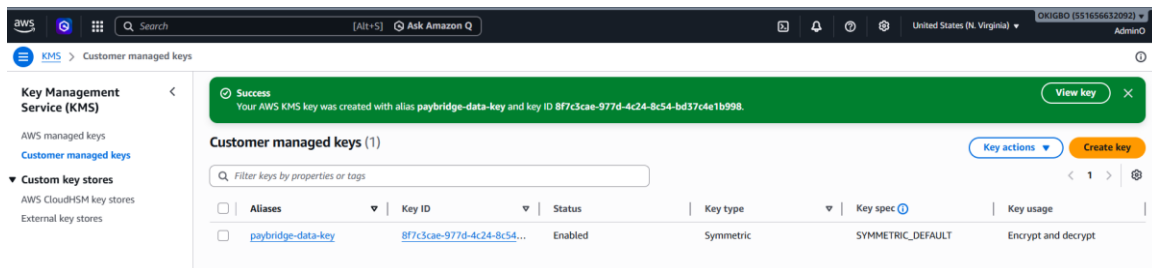


Figure 4.1 - KMS Customer managed keys page showing paybridge-data-key with status Enabled.

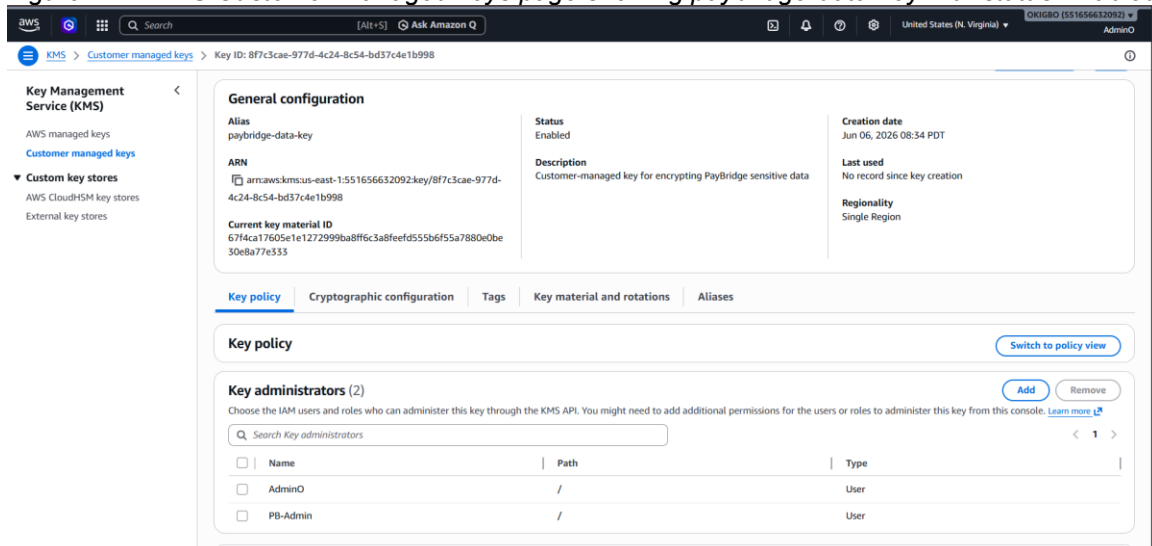


Figure 4.2 - KMS key detail view showing the alias, ARN, and the key administrators policy.

4.5 Object Storage (S3)

Creates durable storage for transaction exports and merchant documents, encrypted with the KMS key from 4.4 and locked down from public access.

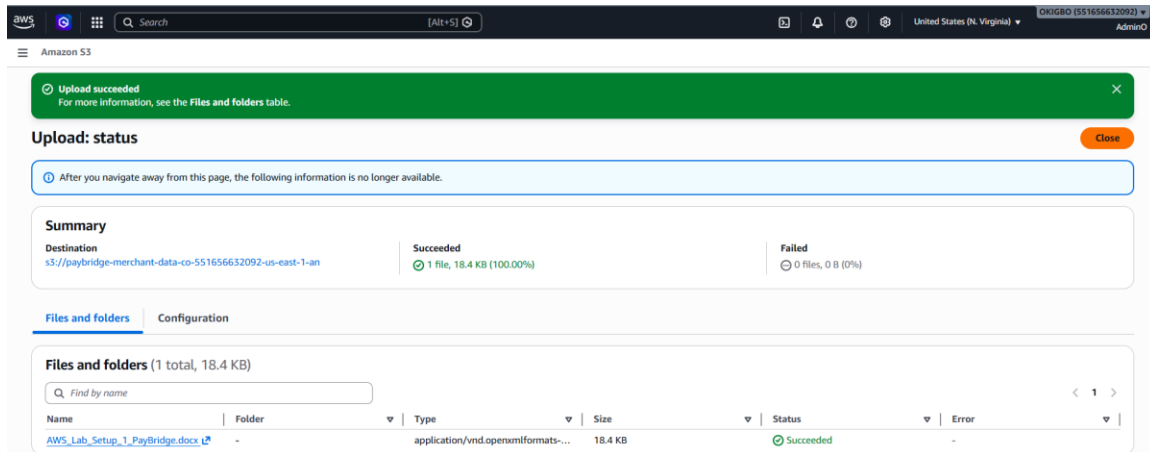


Figure 5.1 - Successful upload of a sample file into the paybridge-merchant-data S3 bucket.

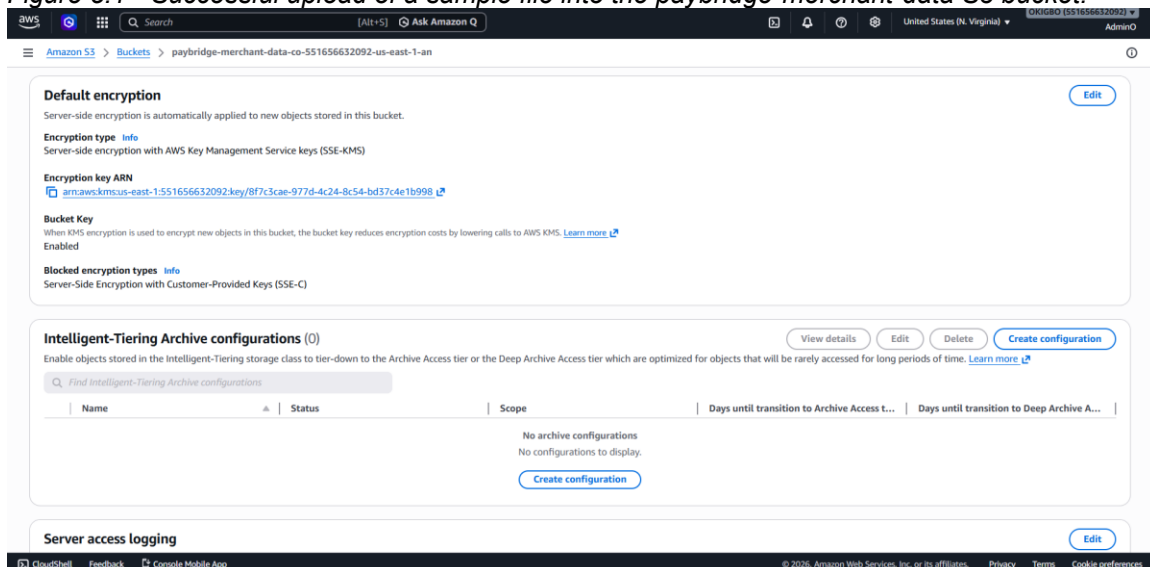


Figure 5.2 - S3 bucket Properties showing default encryption set to SSE-KMS using the paybridge-data-key.

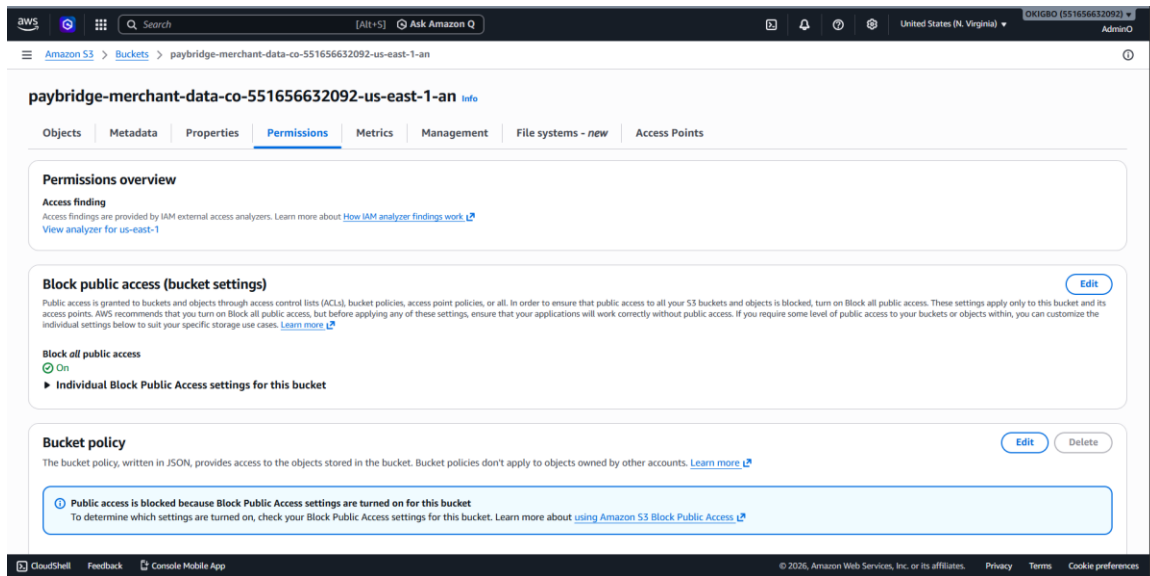


Figure 5.3 - S3 bucket Permissions tab confirming Block Public Access is On.

4.6 Audit Logging (CloudTrail)

Provides the tamper evident record of all account activity required for PCI Req. 10 and the SOX audit trail.

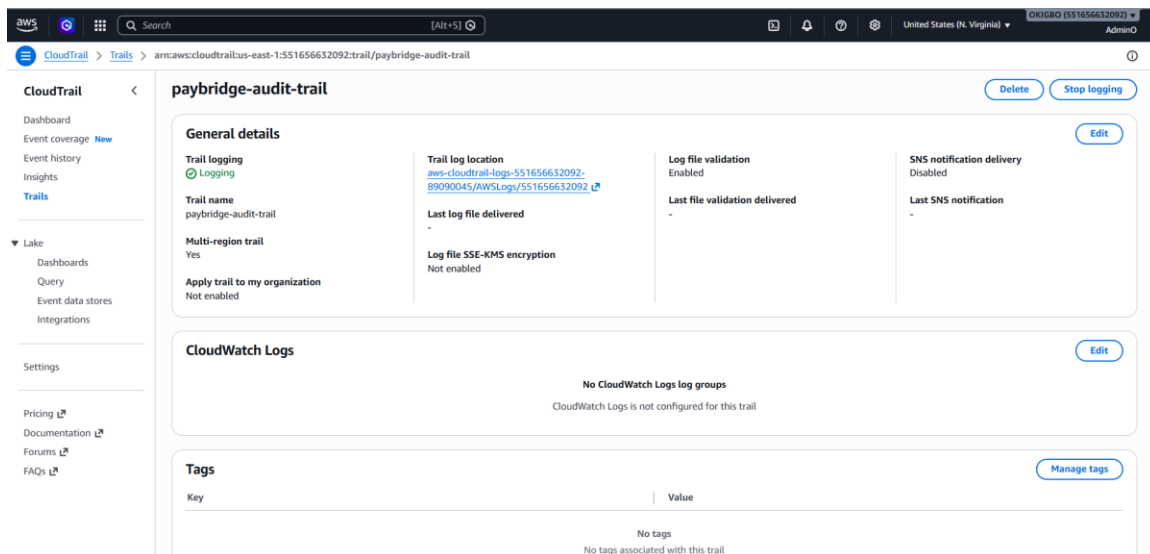


Figure 6.1 - CloudTrail paybridge-audit-trail detail page showing the trail is actively Logging with its destination log bucket.

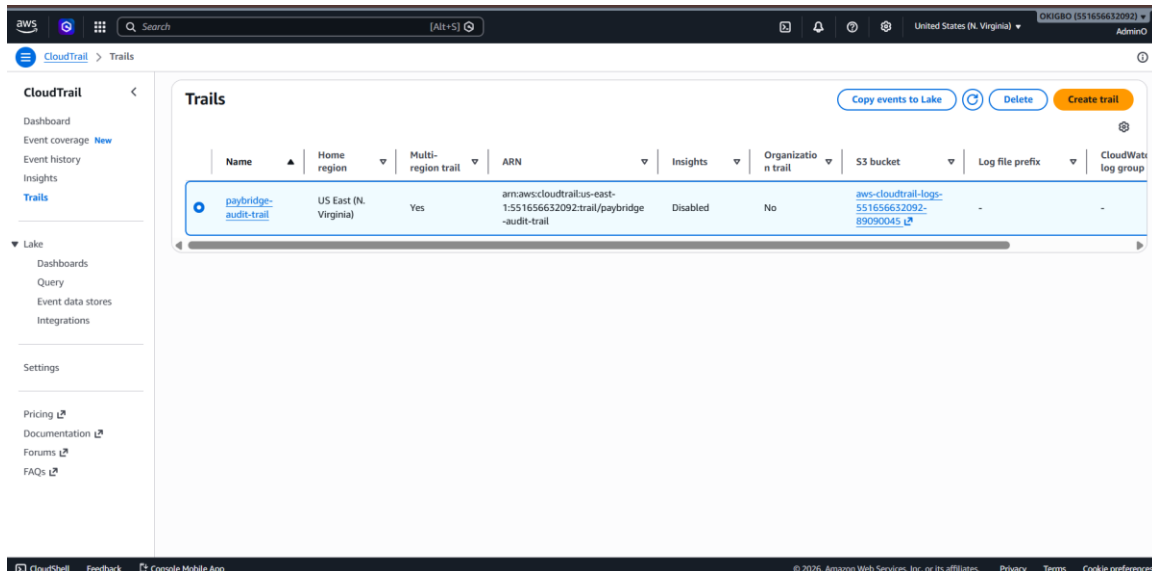


Figure 6.2 - CloudTrail Trails list confirming paybridge-audit-trail is multi region and active.

4.7 Monitoring (CloudWatch)

Delivers the health monitoring and anomaly alerting required by F6 and N3.

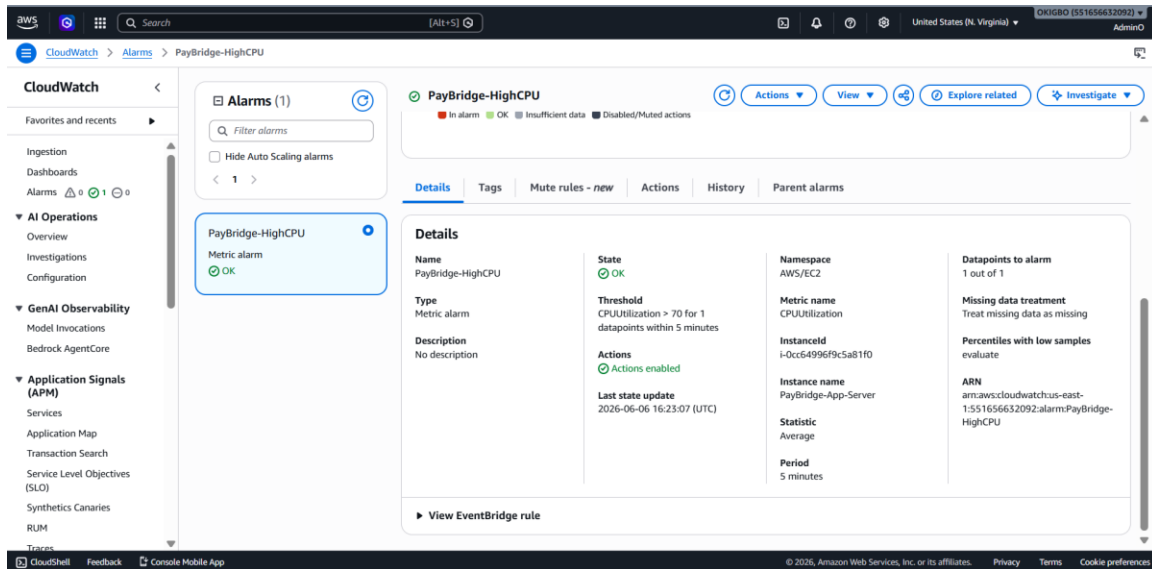


Figure 7.1 - CloudWatch PayBridge-HighCPU alarm detail page showing the metric, threshold, and current OK state.

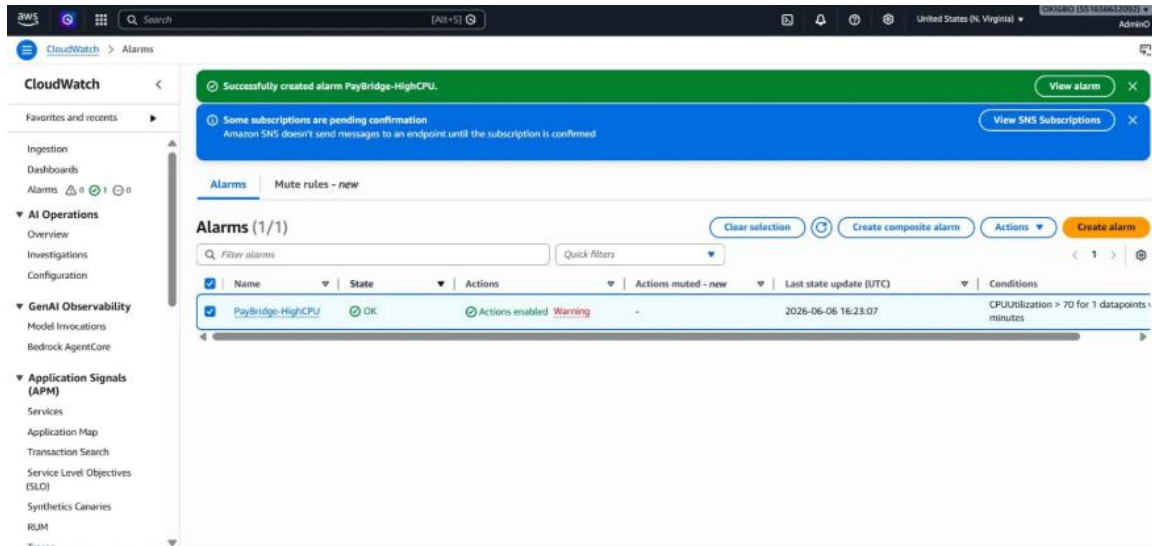


Figure 7.2 - CloudWatch Alarms list confirming PayBridge-HighCPU was created and is active.

5. Summary

This lab built a security and compliance focused AWS environment for PayBridge Inc., a fictional FinTech startup. Identity is centralized in IAM with role based, MFA protected access. The application runs on an EC2 server inside a restricted network boundary. Sensitive data is stored in S3 and encrypted with a customer managed KMS key, reflecting a zero trust posture. The environment is made auditable through CloudTrail logging and CloudWatch monitoring. Each control was chosen to satisfy a defined business requirement and to map directly to PCI-DSS and SOX obligations.